

WEB APPLICATION

Security Audit Report

Author: Alexander Solomon Ushahemba

Target: ASU.TECH Portfolio (asu.tech)

Standard: OWASP Top 10 (2021)

Date: June 2026

Audit Type	White-box (source code + live testing)
Standard	OWASP Top 10 2021
Total Tests	24 test cases across 10 categories
Overall Rating	B+ (Minor issues found — no critical vulnerabilities)

SCOPE & OBJECTIVES

Audit Scope

This security audit was conducted against the ASU.TECH personal portfolio website. The goal was to identify and remediate common web application vulnerabilities as defined by the OWASP Top 10 2021 standard, and to validate that the application meets baseline security requirements before public deployment.

OWASP TOP 10 RESULTS

Test Results by Category

#	Category	Tests	Result	Risk
A01	Broken Access Control	3	PASS	None
A02	Cryptographic Failures	2	PASS	None
A03	Injection (XSS / SQLi)	4	WARN	Low
A04	Insecure Design	2	PASS	None
A05	Security Misconfiguration	3	WARN	Low
A06	Vulnerable Components	2	PASS	None
A07	Auth & Session Failures	2	N/A	None
A08	Software Integrity Failures	2	PASS	None
A09	Logging & Monitoring	2	WARN	Low
A10	Server-Side Request Forgery	2	PASS	None

FINDINGS

Detailed Findings

[LOW] WAF-001 — Missing Content Security Policy Header	
Description	The application does not set a Content-Security-Policy HTTP response header, which increases risk of cross-site scripting (XSS) attacks.
Remediation	Add CSP header via server config or meta tag: Content-Security-Policy: default-src 'self'; script-src 'self'

[LOW] WAF-002 — Contact Form — No Rate Limiting	
Description	The contact form accepts unlimited submissions with no CAPTCHA or rate limit, making it susceptible to spam and denial-of-service (DoS) attacks.
Remediation	Implement server-side rate limiting. Add Google reCAPTCHA v3 to the form.

[INFO] WAF-003 — Server Version Disclosure	
Description	HTTP response headers reveal server software version, providing attackers with fingerprinting information.
Remediation	Configure server to suppress X-Powered-By and Server response headers.

[LOW] WAF-004 — No HTTPS Redirect from HTTP	
Description	Visiting the site over HTTP does not automatically redirect to HTTPS, allowing potential plaintext session interception.
Remediation	Add 301 redirect rule: all HTTP traffic -> HTTPS. Enable HSTS header.

CONCLUSION

Conclusion

The ASU.TECH web application demonstrates a solid security baseline with no critical or high-severity vulnerabilities identified. The findings are limited to low-risk hardening opportunities and informational items. Applying the recommended remediations will bring the application to a strong security posture suitable for public-facing deployment.